

SOC 2 Scoping Document : BrightLoop Analytics

Document Owner: GRC Analyst

Approved By: CISO / Executive Management

Version: 1.0

Approval Date: 2026-07-26

Next Review: Upon material system change or before each audit cycle

System Boundary Version: BrightLoop Production Environment v1.0

Trust Services Criteria Selected

TSC	In Scope?	Business Justification
Security (Common Criteria)	Yes / Mandatory	BrightLoop is a B2B SaaS provider pursuing SOC 2 to support pending enterprise customer deals. Security is the primary criterion for evaluating whether the company's systems are protected against unauthorized access, use, or modification.
Availability	No / Future Consideration	The current business context does not identify a specific contractual uptime or availability requirement requiring Availability to be included in the initial SOC 2 scope. This criterion may be added if future enterprise contracts establish formal availability commitments.
Processing Integrity	No	BrightLoop provides marketing analytics services but does not process financial transactions or perform a customer business process where a separate Processing Integrity examination is currently required.
Confidentiality	No / Future Consideration	BrightLoop processes customer business analytics data that may have commercial sensitivity. However, the current business context does not establish a separate contractual or management-defined Confidentiality commitment requiring this TSC to be included in the initial examination.
Privacy	No	BrightLoop is not described as processing significant sensitive personal information or acting as a data controller for end-consumer personal data. Privacy is therefore excluded from the initial SOC 2 scope.

Final Initial Scope

Security / Common Criteria only

The initial SOC 2 scope is intentionally focused on Security because it directly addresses BrightLoop's current enterprise customer requirements without expanding the examination to additional Trust Services Criteria that are not currently supported by specific contractual or business requirements.

System Boundary

In Scope:

- AWS production infrastructure supporting the BrightLoop Analytics platform
- Production application environment
- Production customer database
- Identity and access management systems supporting access to in-scope systems
- Microsoft 365 services relevant to security and business operations
- Customer support platform used to support the production service
- CI/CD pipeline used for production deployments
- Personnel responsible for developing, operating, securing, and supporting the production environment
- Security, access management, incident response, change management, and vendor management processes supporting the production environment

Out of Scope:

- Internal HR systems and processes unrelated to the security of the production environment
- Marketing website infrastructure
- Development and sandbox environments that do not contain production customer data or provide access to production systems
- Personal systems not used to perform BrightLoop business or production support activities
- Business processes unrelated to the operation and security of the BrightLoop Analytics platform

Report Type & Timeline

Report Type: SOC 2 Type II

BrightLoop should remediate its highest-priority readiness gaps before beginning the observation period. Following remediation, the company should operate and collect evidence for a minimum six-month observation period.

A direct Type II approach is recommended because the company's pending enterprise customer requirements are expected to require evidence that controls operated consistently over time.

Type II Observation Window: [Start Date] to [End Date] — minimum 6 months

Planned Assessment Sequence

1. Complete SOC 2 readiness assessment
2. Remediate high-severity gaps
3. Implement and document required controls
4. Begin the six-month Type II observation period
5. Undergo the SOC 2 Type II examination

Scope Change Management

This document must be reviewed when a material change occurs to:

- The production architecture
- Customer data types processed
- Major third-party service providers
- Customer contractual requirements
- Security or availability commitments
- The organization's business model
- Systems supporting the production environment

Material changes may require an update to the selected Trust Services Criteria or the system boundary.

Approval

Approved by: Aryan Neupane_____

Title: _____ GRC Analyst_____

Signature: _____Aryan_____

Date: _____2026-07-26_____

